GlobalTech Inc.

Quantitative Phishing Risk Assessment and Control Investment Analysis

---

To: Board of Directors, CISO, CFO

From: Rosemary Gift Nelson, GRC Risk Analysis Team (Registration C11/26/CGRCE-17216)

Date: 29th October 2026

Subject: Corrected Quantitative Phishing Risk Assessment and Control Investment Analysis

***A note on scope**: This report corrects four calculation errors and documents several assumptions found in the original lab brief's worked example, per this assignment's own submission instructions. Full formula-level detail for every figure below is in the accompanying calculation workbook (GRC103_Lab3A_Calculation_Workbook), Assumptions sheet. The brief's own flawed figures are retained in a clearly labeled reference section of that workbook for comparison and are not used anywhere in this report.*

1. Executive Summary

Our phishing simulation analysis of three campaigns (430 emails sent across the organization) finds an overall credential submission rate of 24.4% and a corrected Annualized Loss Expectancy (ALE) of $1,087,500. This figure replaces the brief's original worked example, which reported a $652.5 million ALE; that number resulted from treating 600 individually compromised employee credentials as 600 separate full-scale organizational breaches, rather than applying the dataset's stated 25% breach probability once, at the organizational level. The corrected exposure is real and actionable, but it is roughly 600 times smaller than the brief's original figure, and our recommendations are sized accordingly.

The "IT System Password Reset" campaign (Campaign B) is the highest-risk finding: a 30.0% credential submission rate, the largest tested population (250 employees), and the largest projected at-risk headcount (600 employees). We recommend immediate deployment of multi-factor authentication (MFA) enterprise-wide, which alone is projected to reduce the Annual Rate of Occurrence (ARO) by 99.9% and deliver a standalone ROI above 1,100%. Combined with security awareness training and email filtering, total projected first-year risk reduction is between $1.09 million (rigorous combined scenario) and $2.61 million (sum of each control's independent effect), against a combined investment of $240,000.

2. Key Quantitative Findings

Figures below are independently calculated from the supplied campaign dataset and verified in the accompanying workbook (Financial Risk Calcs and Control Recommendations sheets); no industry-benchmark figures are presented as verified data for this organization.

Risk Metric	Corrected Value	Brief's Original (Flawed) Value	Severity
Overall Credential Theft Rate (blended, independently verified: 105/430 submissions)	24.4%	22.1% (not traceable to the dataset)	HIGH
Maximum Campaign Credential Submission Rate (Campaign B)	30.0%	30.0% (figure itself correct)	CRITICAL
Annualized Loss Expectancy (SLE x ARO)	$1,087,500	$652,500,000 (headcount-as-breach-count error)	SIGNIFICANT
Combined 1-Year ROI, all 3 controls (sum of independent effects)	987.0%	n/a (brief computed each control separately at 724,175% / 391,400% / 260,800%)	STRONG

The brief's executive summary table also quoted an "Industry Average" column (15.3% theft rate, $285M ALE, 350% MFA ROI, among others). No source for those figures was supplied with this assignment, so per the submission instruction to treat unverified benchmarks as scenario assumptions rather than verified data, they are omitted from this report rather than restated as fact.

3. Detailed Financial Analysis

Current-State Risk

- Single Loss Expectancy (SLE): $4,350,000 (stated cost of a major data breach)
- Annual Rate of Occurrence (ARO): 25.0% (the dataset's "Probability of Major Breach if Credentials Stolen" figure, applied directly as the organization's annual breach probability, not multiplied by a per-campaign headcount)
- Annualized Loss Expectancy (ALE = SLE x ARO): $4,350,000 x 25% = $1,087,500
- Per-Employee Risk (ALE / 2,000 employees): $1,087,500 / 2,000 = $543.75

The brief's unsupported "Probability of Major Breach: 93.75%" figure is not reproduced here; it has no traceable derivation from the supplied dataset and is treated as an assumption error (see workbook, Correction 4).

Proposed Security Investment Portfolio (controls with modeled effectiveness)

Control	Cost	Risk Reduction	Net Benefit	ROI	Priority
Multi-Factor Authentication (MFA)	$90,000	$1,086,413	$996,413	1,107%	1
Security Training	$100,000	$652,500	$552,500	553%	2
Email Filtering	$50,000	$870,000	$820,000	1,640%	3
TOTAL (sum of each control's independent effect)	**$240,000**	**$2,608,913**	**$2,368,913**	**987%**	

Each control's ROI above is calculated against the same $1,087,500 current-state baseline, independently of the other two controls, which is standard practice for comparing individual control value and matches this lab's Control Recommendation Table format. Because the three reductions overlap (they are not three independent risks but three ways of reducing the same single organizational ARO), simply summing them to $2,608,913 overstates what deploying all three together actually achieves. Section 5 below presents a second, more rigorous figure for that combined scenario.

4. Strategic Recommendations

Immediate Actions (Q1)

- Implement MFA enterprise-wide - $90,000 (modeled: 1,107% first-year ROI; see Section 3)
- Conduct emergency security awareness training - $100,000 (modeled: 553% first-year ROI)
- Launch a targeted phishing-simulation refresher program using the HR Bonus Notification pretext, which tested as Campaign A's effective lure - $25,000 (cost only; no independent effectiveness figure was supplied, so no ROI is claimed for this line)

Strategic Initiatives (FY2027)

- Deploy an advanced email security gateway - $50,000 (modeled: 1,640% first-year ROI, using an assumed 80% filtering effectiveness; see workbook Assumption B)
- Establish continuous security monitoring - $150,000 (cost only; not independently modeled)
- Implement security behavior analytics - $75,000 (cost only; not independently modeled).

The brief's own Strategic Recommendations list totals $490,000 across six line items, and its Bonus Challenge hint uses that $490,000 figure. Only three of those six items (MFA, Training, Email Filtering, totaling $240,000) have a stated or assumed effectiveness percentage in the dataset and can be modeled with a defensible ROI; the other three (phishing-simulation refresher, continuous monitoring, behavior analytics) are retained above as sound complementary recommendations, priced at their stated cost, but without a fabricated ROI figure. The Bonus Challenge break-even analysis in Section 6 therefore uses the $240,000 figure, consistent with the Control Recommendation Table (Deliverable 5).

5. Expected Risk Posture After Controls

Metric	Current State	With Controls (sum of independent effects)	With Controls (rigorous combined scenario)
Credential Theft Rate	24.4%	n/a - see note	1.95% (Training + Filtering applied sequentially)
Annual Rate of Occurrence (breach probability)	25.0%	n/a - see note	0.002%
Annualized Loss Expectancy	$1,087,500	n/a - see note	$87
Risk Reduction vs. current state	-	$2,608,913 (987% ROI)	$1,087,413 (453% ROI)

Two combined-deployment figures are presented deliberately. The "sum of independent effects" column matches the Control Recommendation Table in the accompanying workbook (each control's benefit measured on its own against the same baseline) and is the figure to use when comparing controls against each other. The "rigorous combined scenario" models what happens if all three are deployed together: Security Training and Email Filtering both reduce the Credential Theft Rate, so their effects are applied sequentially (24.4% x (1-60%) x (1-80%) = 1.95%), which scales the ARO proportionally to 2.0%; MFA is then applied to that result, reducing the ARO by a further 99.9% to 0.002%. The resulting ALE of $87 and ROI of 453% are lower than the simple sum (987%) but materially more defensible, since they do not double-count overlapping risk reduction. Both figures are legitimate; they answer different questions, and we recommend the Board use the rigorous combined figure (453% ROI, breach probability reduced by 99.99%) when evaluating the portfolio as a single investment decision.

6. Bonus Challenge: Break-Even Point

Using the $240,000 total investment in the three modeled controls (see Section 4 note) against the stated $4,350,000 single-breach cost: Break-even = $240,000 / $4,350,000 = 0.0552 breaches. In other words, preventing just 5.5% of a single average breach's worth of expected loss, about one-eighteenth of one breach, justifies the entire $240,000 combined investment. Since the corrected current-state ARO (25%) falls to a small fraction of that once MFA alone is deployed, the investment clears this break-even threshold many times over under any of the scenarios modeled in Section 5.

Appendix: Corrections to the Brief's Worked Example

Per this assignment's submission instructions ("Some worked examples in the brief contain calculation errors or unsupported assumptions. Independently verify the figures and explain any corrections"), the following four corrections were identified and applied throughout this report and the accompanying workbook. Full formula-level detail is on the workbook's Assumptions sheet.

Correction 1 - Breach count conflated with annual occurrence rate (the core error)

The brief's worked example projects 600 employees with compromised credentials for Campaign B (2,000 x 30%), multiplies by the stated 25% breach probability to get "150 expected breaches," then multiplies $4,350,000 x 150 = $652,500,000. This treats a headcount of people whose credentials were phished as a count of major breach events, and it multiplies that headcount by the organization's current level of credential-theft exposure a second time (the 25% figure already reflects how likely stolen credentials are to cause a major breach). We treat the dataset's 25% figure as the Annual Rate of Occurrence itself, applied once at the organizational level: ALE = SLE x ARO = $4,350,000 x 0.25 = $1,087,500.

Correction 2 - Overall Credential Theft Rate does not reproduce from the dataset

The brief's executive summary states "Overall Credential Theft Rate: 22.1%." Recalculating directly from the supplied data (Total Credentials Submitted / Total Emails Sent = (18+75+12)/(100+250+80) = 105/430) gives 24.4%, not 22.1%. This report uses the independently verified 24.4% figure throughout.

Correction 3 - Security Training calculation mislabels which rate it reduces

The brief's Step 5 states "New Click-Through Rate: 30% x (1-0.60) = 12%," but 30% is Campaign B's Credential Submission Rate, not its Click-Through Rate (which is 60%, i.e. 150/250). The brief's own subsequent arithmetic ("New Credentials Stolen: 2,000 x 0.12 = 240") confirms it is actually operating on the credential rate throughout, just mislabeled. This report corrects the label: Security Training's stated 60% effectiveness is applied to the organization's overall Credential Theft Rate, consistent with

what the brief's own numbers actually compute, and consistent with the submission instruction to distinguish click-through rates from credential submission rates.

Correction 4 - Unsupported "Probability of Major Breach: 93.75%" figure

The brief's executive summary states breach probability rises to 93.75% without any traceable derivation from the supplied dataset. This report does not reproduce that figure; current-state ARO is held at the dataset's stated 25%, since no functional relationship between exposure scale and breach probability was supplied (inventing one would itself violate the instruction to use only the supplied dataset).

Key Assumptions

- Controls affect ARO through two mechanisms: rate-reducing controls (Training, Email Filtering) scale ARO proportionally to their reduction of the Credential Theft Rate; MFA does not stop credential theft but neutralizes its impact, so it is applied directly to ARO (New ARO = Current ARO x (1 - 0.999)).
- Email Filtering effectiveness is assumed at 80% (the brief supplies a cost but no effectiveness percentage for this control; 80% is the midpoint of a commonly cited 70%-90% industry range for modern email security gateways, flagged here as an external benchmark, not verified data for this scenario).
- All figures in this report are one-year (annual); no multi-year evaluation period was requested by this brief, unlike Lab 3B.
- Confidence intervals (Section 2 of the accompanying workbook's Statistical Analysis sheet) are calculated per campaign using each campaign's own sample size and are independent of the financial corrections above; the brief's own confidence-interval formula and worked example for Campaign B are verified as arithmetically correct and used as the template for Campaigns A and C.

Prepared by Rosemary Gift Nelson, Registration C11/26/CGRCE-17216, Cohort 11/Batch A, ICDFA GRC103.